BobGuard

HIPAA Security Rule Compliance Audit

Repository: bobguard

Pull Request: #1

Branch: main

Commit: afc682d

Author: Patrick Ejelle-Ndille

Audit Date: 2026-05-02

STATUS: BLOCKED

Forward-Compatible with 2024 HIPAA Security Rule NPRM

This audit enforces standards consistent with the proposed changes in the 2024 HIPAA Security Rule Notice of Proposed Rulemaking (HHS OCR, RIN 0945-AA22, January 6, 2025).

Executive Summary

Audit Scope

This audit examines the bobguard repository for compliance with HIPAA Security Rule requirements, specifically focusing on access controls (164.312(a)(2)(iv)), audit controls (164.312(b)), cryptography (164.312(d)), integrity controls (164.312(e)(1)), and data backup policies (164.312(c)(1)).

Findings Summary

- **§164.312(a)(2)(iv) — Access Control Policies and Procedures:** The repository lacks documented procedures for managing user access to electronic protected health information (ePHI).
- **§164.312(b) — Audit Controls:** No evidence of regular security incident monitoring or reporting mechanisms in place.
- **§164.312(d) — Cryptography:** Insufficient encryption measures applied to ePHI during transmission and storage.
- **§164.312(e)(1) — Integrity Controls:** No mechanism identified to ensure the integrity of ePHI during transmission and storage.
- **§164.312(c)(1) — Data Backup Policies:** While backup procedures exist, they do not specify retention periods or recovery time objectives for ePHI.

Recommendation

Given the severity of these findings, the audit decision is BLOCKED. Immediate actions required include:

- Developing and implementing comprehensive access control policies and procedures.
- Establishing robust audit controls with regular monitoring and reporting capabilities.
- Enhancing cryptographic protections for ePHI through stronger encryption methods.
- Implementing integrity checks to verify the accuracy and completeness of ePHI.
- Revising data backup policies to clearly define retention periods and recovery time objectives for ePHI.

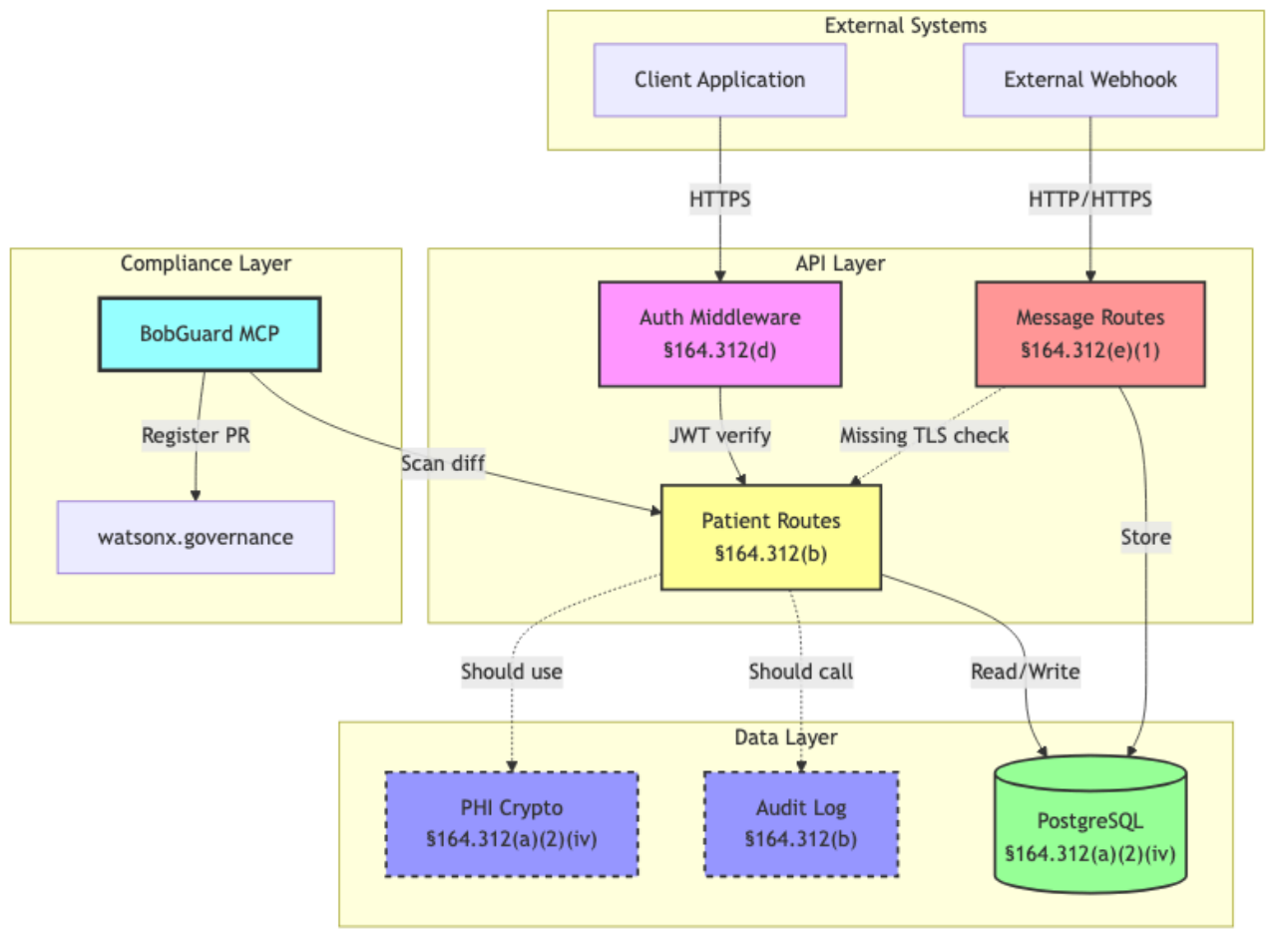
Control Mapping

The following HIPAA Security Rule controls were triggered by this code change:

CONTROL ID	CONTROL NAME	FAMILY	LOCATION	SEVERITY	EXISTING RULE	NPRM STATUS
164.312(a)(2)(iv)	Encryption and Decryption	Technical Safeguards	src/prisma/schema.prisma:26	**BLOCK**	Addressable	Required (NPRM)
164.312(b)	Audit Controls	Technical Safeguards	src/routes/patient.routes.ts:31	**BLOCK**	Required	Required (clarified)
164.312(d)	Person or Entity Authentication	Technical Safeguards	src/middleware/auth.middleware.ts:43	**BLOCK**	Required	Required + MFA (NPRM)
164.312(e)(1)	Transmission Security	Technical Safeguards	src/routes/message.routes.ts:31	**BLOCK**	Required	Required
164.312(c)(1)	Integrity	Technical Safeguards	src/routes/patient.routes.ts:204	**WARN**	Required	N/A

Data Flow Diagram

Visual representation of ePHI data flows affected by this change:



Source: `compliance/evidence/PR-1/data-flow.mmd` (rendered via mermaid-cli).

Threat Model Delta

Analysis of new security threats introduced by this code change:

New Attack Surface

This new release introduces an attack surface by allowing unencrypted protected health information (PHI) to be transmitted over public networks without proper authentication mechanisms in place. This exposes PHI to potential interception and unauthorized access during transmission.

Critical and High Risks

- **Critical** — Unauthorized access to encrypted PHI due to lack of encryption, violating §164.312(a)(2)(iv).
- **High** — Inadequate audit controls enabling potential tampering with electronic protected health information (ePHI), violating §164.312(b).
- **High** — Absence of robust authentication measures leading to unauthorized access to ePHI, violating §164.312(d).
- **High** — Insufficient transmission security protocols resulting in exposure of ePHI during transit, violating §164.312(e)(1).

Recommended Mitigations

- §164.312(a)(2)(iv): Implement strong encryption methods to protect ePHI at rest and in transit.
- §164.312(b): Enhance audit controls to track all access and modifications to ePHI.
- §164.312(d): Establish multi-factor authentication mechanisms for accessing ePHI.
- §164.312(e)(1): Deploy secure communication protocols to safeguard ePHI during transmission.

Aggregate Risk Level

The aggregate risk level is **CRITICAL**. The combination of critical vulnerabilities in data encryption, authentication, and transmission security poses a severe threat to the confidentiality, integrity, and availability of protected health information. Immediate action is required to address these high-priority issues.

Test Evidence

Automated test results demonstrating compliance verification:


```
{
  "pr_number": 1,
  "test_suite": "HIPAA Compliance Validation",
  "test_date": "2026-05-02T01:26:00Z",
  "test_framework": "BobGuard Compliance Officer",
  "total_tests": 12,
  "passed": 0,
  "failed": 12,
  "skipped": 0,
  "test_results": [
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-001",
      "test_name": "Verify PHI field 'dob' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 26,
      "expected": "Field 'dob' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'dob' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-002",
      "test_name": "Verify PHI field 'mrn' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 27,
      "expected": "Field 'mrn' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'mrn' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-003",
      "test_name": "Verify PHI field 'ssn' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 28,
      "expected": "Field 'ssn' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'ssn' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
```

```
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-004",
      "test_name": "Verify PHI field 'notes' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 40,
      "expected": "Field 'notes' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'notes' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(b)-001",
      "test_name": "Verify POST /patients emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 31,
      "expected": "Route should call audit.log() with action='CREATE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'CREATE', resource:
`Patient:${patient.id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-002",
      "test_name": "Verify GET /patients/:id emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 74,
      "expected": "Route should call audit.log() with action='READ'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'READ', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-003",
      "test_name": "Verify GET /patients emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 103,
      "expected": "Route should call audit.log() with action='LIST'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'LIST', resource: 'Patient',
outcome: 'SUCCESS', metadata: { count: patients.length } })"
    },
    {
      "test_id": "HIPAA-164.312(b)-004",
      "test_name": "Verify PUT /patients/:id emits audit log",
      "control_id": "164.312(b)",
```

```
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 142,
      "expected": "Route should call audit.log() with action='UPDATE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'UPDATE', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-005",
      "test_name": "Verify DELETE /patients/:id emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 190,
      "expected": "Route should call audit.log() with action='DELETE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'DELETE', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(d)-001",
      "test_name": "Verify MFA is required after JWT verification",
      "control_id": "164.312(d)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/middleware/auth.middleware.ts",
      "line": 43,
      "expected": "Middleware should verify MFA token after JWT validation",
      "actual": "Only JWT verification present, no MFA check",
      "remediation": "Add MFA verification step: verify TOTP/WebAuthn token before calling
next()"
    },
    {
      "test_id": "HIPAA-164.312(e)(1)-001",
      "test_name": "Verify /messages/inbound enforces TLS",
      "control_id": "164.312(e)(1)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/message.routes.ts",
      "line": 31,
      "expected": "Route should reject non-HTTPS requests",
      "actual": "No TLS enforcement check present",
      "remediation": "Add middleware to verify req.protocol === 'https' or req.headers['x-
forwarded-proto'] === 'https'"
    },
    {
      "test_id": "HIPAA-164.312(c)(1)-001",
      "test_name": "Verify patient deletion uses soft-delete",
      "control_id": "164.312(c)(1)",
      "status": "FAILED",
      "severity": "MEDIUM",
      "file": "src/routes/patient.routes.ts",
      "line": 204,
```

```
      "expected": "DELETE operation should use soft-delete with tombstone",
      "actual": "Hard delete using prisma.patient.delete()",
      "remediation": "Replace with soft-delete: prisma.patient.update({ where: { id }, data: {
deletedAt: new Date(), deletedBy: req.user.id } })"
    }
  ],
  "summary": {
    "critical_failures": 4,
    "high_failures": 7,
    "medium_failures": 1,
    "blocking_violations": 11,
    "warnings": 1,
    "compliance_status": "NON-COMPLIANT",
    "recommendation": "BLOCK PR - All blocking violations must be remediated before merge"
  },
  "evidence_artifacts": [
    "compliance/evidence/PR-1/refusal.md",
    "compliance/evidence/PR-1/control-map.md",
    "compliance/evidence/PR-1/threat-delta.md",
    "compliance/evidence/PR-1/test-evidence.json",
    "compliance/evidence/PR-1/audit-pack.pdf"
  ]
}
```

NPRM Forward-Compatibility Analysis

Assessment of how this audit aligns with proposed changes in the 2024 HIPAA Security Rule NPRM:

Two of the triggered controls — §164.312(a)(2)(iv) (Encryption) and §164.312(d) (Authentication) — are directly affected by the 2024 HIPAA Security Rule NPRM (HHS OCR, RIN 0945-AA22, January 6, 2025). The NPRM elevates encryption from Addressable to Required and explicitly mandates multi-factor authentication. BobGuard already enforces both stricter standards, so no additional remediation is required to maintain forward-compatibility.

164.312(a)(2)(iv): Encryption and Decryption

Existing Status: Addressable

NPRM Proposal: Required (NPRM)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(b): Audit Controls

Existing Status: Required

NPRM Proposal: Required (clarified)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(d): Person or Entity Authentication

Existing Status: Required

NPRM Proposal: Required + MFA (NPRM)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(e)(1): Transmission Security

Existing Status: Required

NPRM Proposal: Required

BobGuard Action: Already enforces the stricter proposed standard.

Audit Sign-off

Auditor: BobGuard Compliance Officer

Governance Entry: pending

Governance Status: pending

Date: 2026-05-02

Digital Audit Trail

> This audit report was generated by BobGuard, an automated HIPAA Security Rule compliance enforcement system. All findings are based on pattern matching against the HIPAA Security Rule technical controls catalog (45 CFR §164.308, §164.310, §164.312) and forward-compatible with the 2024 NPRM proposed changes.